

3.2 セキュリティの設計

3.2.3 アプリケーションのセキュリティ

3.2.3 アプリケーションのセキュリティ

学習目標とアウトライン

学習目標

- クラウド環境におけるアプリケーションセキュリティの基本的な考え方を学び、セキュリティリスクに対応する方法を理解する
- さくらのクラウドで提供されるアプリケーションセキュリティ関連の機能、サービス、および選択可能なネットワーク構成を理解する

【キーワード】

グローバルネットワークと
ローカルネットワーク

不正アクセス対策

DDoS対策

アウトライン

a. マルチレイヤーセキュリティを検討する

- マルチレイヤーセキュリティ
- 通信パケットのフィルタリング
- WAFの利用
- DDoS対策の検討

b. 役割に応じたネットワーク構成を検討する

- ネットワーク構成の検討

3.2.3 アプリケーションのセキュリティ

マルチレイヤーセキュリティ

マルチレイヤーセキュリティ

検討にあたっての考慮事項

- 単一のセキュリティ対策ではなく、複数のネットワークレイヤーに対して防御手段を重ねることで、アプリケーションのセキュリティを高めることを検討する
- さくらのクラウド利用にあたり、ネットワークセキュリティと境界型防御の観点から、通信パケットのフィルタリングにより不要な通信を遮断するとともに、Webアプリケーションの脆弱性を狙った攻撃の検知・遮断や、DDoS攻撃からの保護を検討する
 - その他、マルウェア対策等も含めて総合的なセキュリティを考慮し、情報セキュリティ管理体制の構築や運用についても検討する

3.2.3 アプリケーションのセキュリティ

通信パケットのフィルタリング

通信パケットのフィルタリング

検討にあたっての考慮事項

- さくらのクラウドでは通信パケットのフィルタリングとして、パケットフィルタ機能やVPNルータのファイアウォール機能を利用することを検討する
 - クラウドのネットワーク構成や、通信パケットのフィルタリングを適用するネットワーク上の位置を考慮して、パケットフィルタ機能がVPNルータのファイアウォール機能を選択する
 - 一つのNICに適用可能なパケットフィルタルール数には最大値があるため、想定されるルール数を検討し適用可能であるかも確認する

通信パケットのフィルタリング

検討にあたっての考慮事項

- パケットフィルタ機能とVPNルータのファイアウォール機能との違いは、以下の通り

	パケットフィルタ機能	VPNルータのファイアウォール機能
機能	ステートレスインスペクション 通信の戻りパケットの自動許可なし	ステートフルインスペクション 通信の戻りパケットの自動許可あり
ネットワーク上の位置	サーバのNICに適用	仮想アプライアンスとして ネットワーク境界に設置
ログ	ルールにマッチした通信をログとして 出力させる機能がない	ルールにマッチした通信をログとして 出力させる機能がある
費用	無料で利用可能	VPNルータの利用料金が発生

通信パケットのフィルタリング

検討にあたっての考慮事項

- パケットフィルタ機能やVPNルータのファイアウォール機能の仕様では対応できない
フィルタリング設定を実現するにあたり、サーバOSのファイアウォール機能等を利用する選択肢がある
 - サーバOSのファイアウォール機能を利用する場合は、動作させる上でサーバOSのリソースが使われることを考慮する
 - マーケットプレイスで提供されているセキュリティアプライアンスを使って、通信パケットをフィルタリングする選択肢もある。ただし、利用者にて各セキュリティメーカーの仕様に従った設定と運用が必要となることを考慮する

パケットフィルタ機能

利用する際のポイント

- パケットフィルタ機能を使うと、サーバ内のファイアウォールなどの設定によらず、コントロールパネル上で簡単にパケット制限を行うことができる
- パケットフィルタ機能で特定の通信のみ許可して他通信を全て拒否したい場合には、最後の順番のルールとして deny アクションのルールを指定する必要があることに注意する
- パケットフィルタ機能を利用するにあたり、良く使われるルールの設定例がクラウドマニユアルに記載されているため参考にできる

パケットフィルタ機能

利用する際のポイント

- ・ パケットフィルタ機能はステートレス動作であることに注意する。最後に全て拒否のルールを設定する場合、サーバ発の通信の戻りパケットを適切に許可する設定が必要となる

【Tips】

共有セグメント配下のサーバにパケットフィルタを適用する場合

共有セグメントに接続されたサーバのNICや、利用者が独自に構築したDHCPサーバを使ってIPアドレスを付与しているサーバのNICにパケットフィルタを適用する場合、DHCPで利用される以下のポートとプロトコルをルール設定で許可する必要があることに注意しましょう。

クライアント側からDHCPサーバ宛のパケットに 67/UDP を許可

DHCPサーバ側からクライアント宛のパケットに 68/UDP を許可

VPNルータのファイアウォール機能

利用する際のポイント

- VPNルータのファイアウォール機能によってクラウドサーバーに対するゲートウェイセキュリティを強化することができる
- VPNルータのファイアウォール機能で特定の通信のみ許可して他通信を全て拒否したい場合には、最後の順番のルールとして deny アクションのルールを指定する必要があることに注意する
- VPNルータのファイアウォールルール設定例は、クラウドマニュアルに記載されているため参考にできる

VPNルータのファイアウォール機能

利用する際のポイント

- VPNルータのファイアウォール機能は、ルール設定時にログ記録を「有効」に選択しないと、ルールにマッチした通信がログ表示機能に出力されないことに注意する（デフォルトは無効）

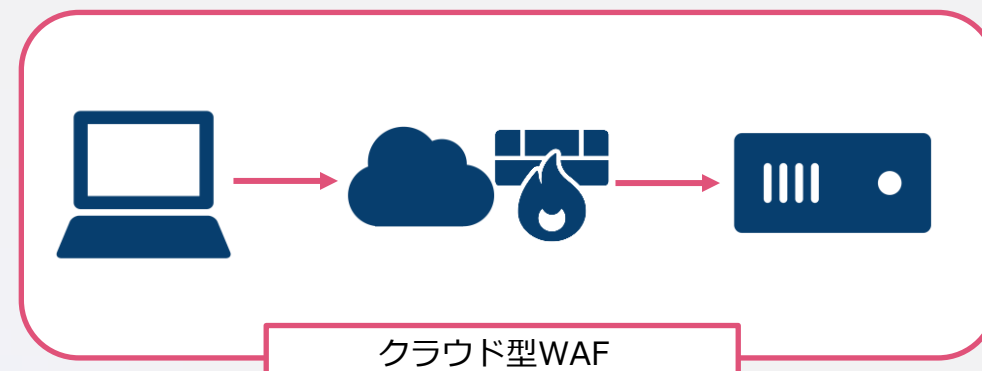
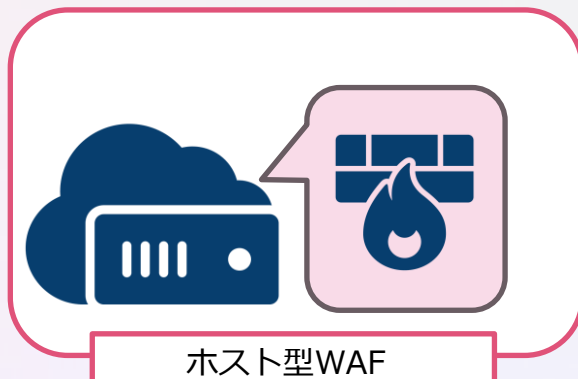
3.2.3 アプリケーションのセキュリティ

WAFの利用

WAFの利用

検討にあたっての考慮事項

- WAF（Web Application Firewall）を導入することで、Webアプリケーションの脆弱性を狙った攻撃の検知と通信の遮断を検討する
- WAFの導入を検討する際は、クラウドのネットワーク構成や環境に合わせて、適切なWAFのタイプを選択する
 - 一般的に、サーバ上でエージェントを稼働させるタイプのホスト型WAFと、セキュリティベンダーが運営するクラウド上のWAFサービスを経由して通信させるクラウド型WAFがある。また、ネットワーク境界に配置したセキュリティアプライアンスのWAF機能を使う選択肢もある



WAFの利用

さくらのクラウドで提供されるWAF

- さくらのクラウドではセキュリティベンダーとの協業により、ホスト型WAF製品を無料で利用することができる。また、マーケットプレイスでは、高機能なホスト型/クラウド型WAFサービスが提供されている
- マーケットプレイスで提供されているセキュリティアプライアンスのWAF機能を利用すると、ネットワーク境界でWAFを利用することができる

【Tips】

ホスト型WAF製品で複数のエージェントを運用する際には、管理画面を利用して一元管理し、運用効率の向上を検討しましょう。セキュリティベンダーの有償ライセンスを購入するか、マーケットプレイスの対象プランを選択して、一元管理を実現できます。また、WAFの設定代行に対応するライセンスもあります。運用負荷を軽減したい場合には利用を検討しましょう。

3.2.3 アプリケーションのセキュリティ

DDoS対策の検討

DDoS対策の検討

検討にあたっての考慮事項

- **必要に応じて、クラウド上で稼働させるアプリケーションに対するDDoS対策を検討する**
 - さくらのクラウドでは、サービス提供基盤全体に対してバックボーンレベルでDDoS対策が講じられており、攻撃を検知した場合はさくらインターネットで状況を確認し、個別に対応が行われる
 - 一般的なDDoS対策としては、接続元ネットワークの制限や、WAFやDDoS対策専用ツール等の利用がある

DDoS対策の検討

さくらのクラウドで提供されるDDoS対策

- エンハンスドロードバランサを利用する構成では、VIPフェイルオーバー機能を利用できる。DDoS攻撃などによりIPアドレスへの到達が失われ疎通が取れなくなった場合に、自動的に別のVIPアドレスに変更される
 - VIPアドレスの無応答検知からフェイルオーバー動作までの目安時間は5分程度となる
- マーケットプレイスで提供されているセキュリティアプライアンスには、DoS攻撃対策の機能を備えたものがある

3.2.3 アプリケーションのセキュリティ

ネットワーク構成の検討

ネットワーク構成の検討

検討にあたっての考慮事項

- ・ サーバの役割と機密性のレベルに応じて、サーバに接続するネットワークを検討する

グローバルネットワークとローカルネットワークの構成

検討にあたっての考慮事項

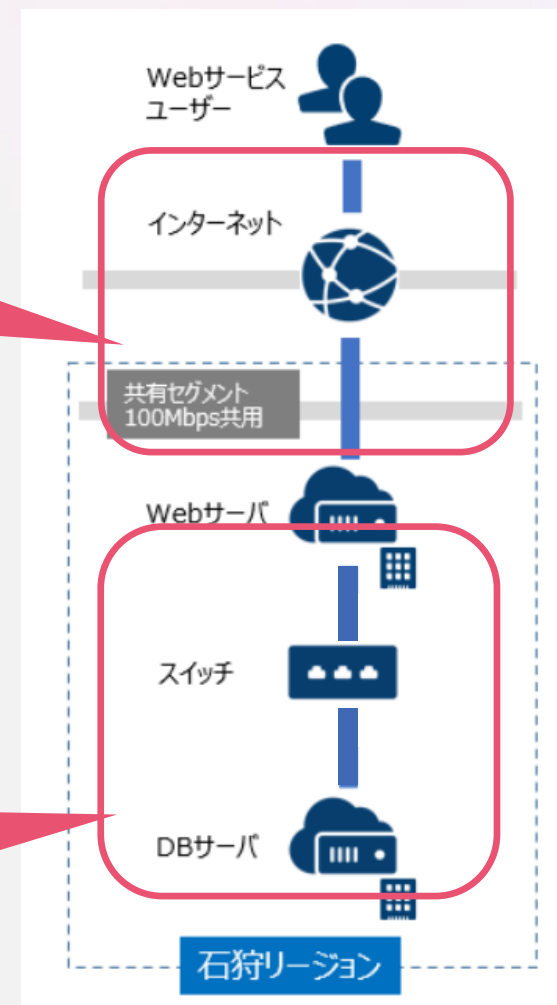
- **グローバルネットワークに接続するサーバは、外部から直接アクセスできることを考慮してセキュリティ対策を実施する**
 - グローバルネットワークに接続するサーバでは機密情報を保管しない
- **ローカルネットワークにのみ接続するサーバは、外部からは直接アクセスできない構成とする**
 - 機密情報を保管するサーバは、ローカルネットワークにのみ接続する

グローバルネットワークとローカルネットワークの構成

インターネット公開サーバの構成例

【グローバルネットワーク】
Webサーバを接続する。
ユーザはグローバルネットワークを経由してWebサーバにアクセスする。DBサーバにアクセスすることはできない。

【ローカルネットワーク】
DBサーバを接続する。
WebサーバはNICを2つ保有し、ローカルネットワークにも接続する。Webサーバはローカルネットワークを経由してDBサーバにアクセスする。



クラウド内部のプライベートネットワークの構成

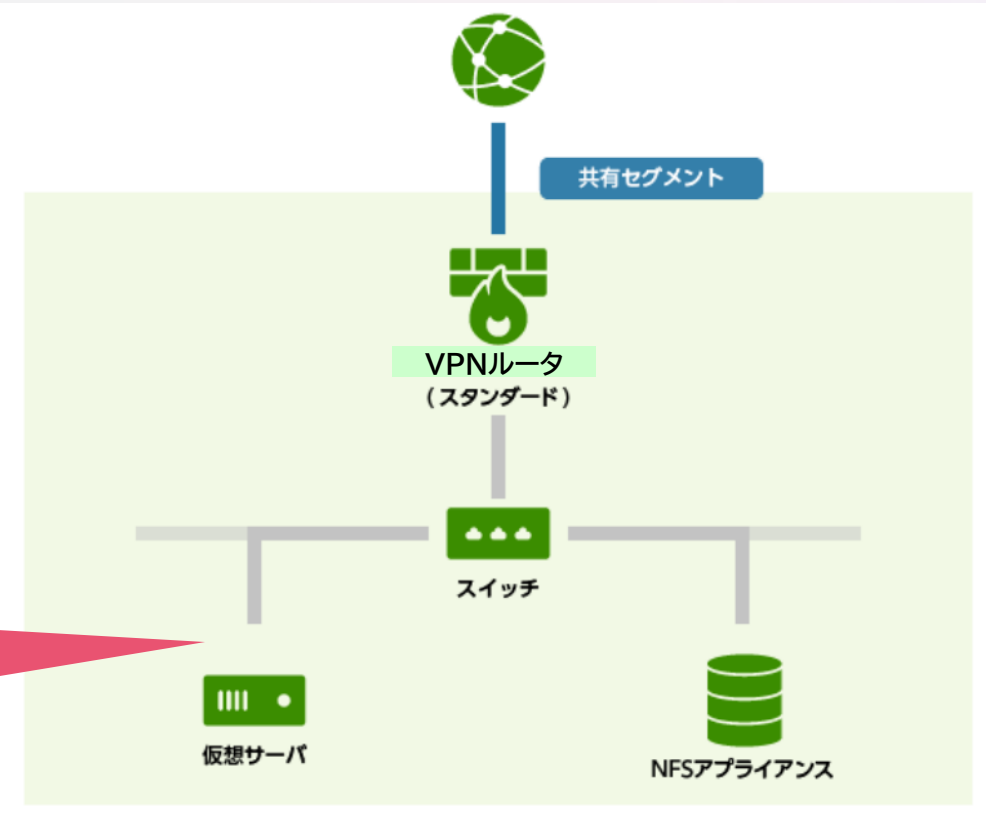
検討にあたっての考慮事項

- インターネットにサーバを公開する場合は、ネットワーク境界にVPNルータを配置する。サーバをクラウド内部のプライベートネットワークに所属させる構成を取ることで、セキュリティの向上を検討する
 - 外部からクラウド内部のプライベートネットワーク内へのアクセスは、VPNルータのポートフォワーディング機能やスタティックNAT機能を使って、クラウド内部のプライベートネットワークに所属するサーバに転送する
 - VPNルータのファイアウォール機能を使って必要な通信のみ許可するように制限する
 - VPNルータ配下のクラウド内部のプライベートネットワークに所属するサーバは、デフォルトゲートウェイのIPアドレスとして、VPNルータのクラウド内部のプライベートネットワーク側NICを指定する

クラウド内部のプライベートネットワークの構成

インターネット公開サーバの構成例

【クラウド内部のプライベートネットワーク】
サーバをクラウド内部のプライベートネットワーク
に所属させる構成を取る。



クラウド内部のプライベートネットワークの構成

インターネット公開サーバの構成例

【Tips】

VPNルータをインターネットと切り離す構成

VPNルータは、複数のクラウド内部のプライベートネットワーク間で通信させることが可能ですが、クラウド内部のプライベートネットワーク内のサーバをVPNルータ経由でインターネットと通信させる必要が無い場合には、VPNルータをインターネットと切り離れた状態で運用することも可能です。



The screenshot shows the configuration page for a 'vpc-router' (VPN Router). The title is 'vpc-router' with a subtitle 'VPCルータ (編集)'. There are three main sections: 'タグ' (Tag) with an input field and a button '任意, ENTERキーで追加'; 'アイコン' (Icon) with a dropdown menu showing '-'; and 'インターネット接続' (Internet Connection) with two radio buttons: '有効' (Enabled) and '無効' (Disabled). The '有効' button is selected and highlighted with a red rectangle. Below the radio buttons, there is a text box explaining the settings: 'インターネット接続を無効にした場合、VPNルータからインターネットに接続できなくなります。インターネットとは切り離し、ローカル内でのみルーティングを行う場合にのみ無効にします。'

【本スライドについてのご案内】

本スライドは、さくらインターネット株式会社により

[CC BY-SA 4.0ライセンス](https://creativecommons.org/licenses/by-sa/4.0/)で提供されています。

ライセンスの条件に従う限り、自由に再利用いただけますので、ぜひご活用ください。

※ 本スライドに、スライドのタイトル・著作権表示・無保証を参照する表示はありません。

※ 「制作協力：アイティーエム株式会社」「制作協力：株式会社 zero to one」との表記につきましては、クレジットとして表示していただく必要はございません。（表示していただくことも問題ございません。）



教材制作・提供：さくらインターネット株式会社

制作協力：アイティーエム株式会社

制作協力：株式会社 zero to one

【クレジット表示について】

スライドを改変せずに再利用する場合

1. 本スライドの各ページには、再利用する場合に必要な次のクレジットが予め表示されています。

This slide is licensed under [CC BY-SA 4.0](https://creativecommons.org/licenses/by-sa/4.0/) by SAKURA internet Inc.

※ 本スライドの全部をそのままお使いになる場合（本スライドのPDFファイルをそのまま再配布される場合等）や、本スライドの一部の再利用であってもクレジット表示のなされているページをそのままお使いになる場合には、重ねて同じ表示をしていただく必要はありません。

2. 印刷して再利用する場合や画像形式に変換して再利用する場合など、リンクを貼ることができない場合には、ライセンス内容が記載された次のURLをご掲載いただくか、本ページも併せてご印刷・ご掲載ください。

<https://creativecommons.org/licenses/by-sa/4.0/deed.ja>

3. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本スライドは、さくらインターネット株式会社により[CC BY-SA 4.0ライセンス](https://creativecommons.org/licenses/by-sa/4.0/)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。

【クレジット表示について】

スライドを改変の上で再利用する場合

1. 改変の上で再利用される場合、次の表示例をご参考にしてください。

This [slide or document] is adapted from the slide by SAKURA internet Inc.
The slide is licensed under [CC BY-SA 4.0](#).
This [slide or document] is licensed under [CC BY-SA 4.0](#) by [Your name here].

2. 和文でクレジット表示をなされる方は、次の表示例をご参考にしてください。

本[スライド・資料等]は、さくらインターネット株式会社制作のスライドを改変の上利用しています。
同スライドは、[CC BY-SA 4.0ライセンス](#)で提供されています。
本[スライド・資料等]は、[スライド・資料等の制作者の氏名・名称]により[CC BY-SA 4.0ライセンス](#)で提供されています。

★上記のクレジットに加えて、合理的に実施可能な場合には、本スライドのURLか本スライドへのリンクをご掲載ください。